



Security Culture 2.0

Enrique Larios-Vargas
Nick Miller

Frontispiece

Copyright and License

Copyright (c) 2026 The OWASP Foundation.

This work is licensed under a [Creative Commons Attribution-ShareAlike 4.0 International License](#). Please read and understand the license and copyright conditions.

Leaders

- Enrique Larios-Vargas
- Nick Miller

Collaborators

- Michael L. W. Vliek
- Nicolas Humblot

SECUR-E Persona-Specific Intervention Guide

Deliverable 6. Contains a complete intervention guide for each of the six SECUR-E developer security personas, grounded exclusively in DASP (Larios-Vargas et al., 2023) and the COM-B Model (Michie, S., van Stralen, M. M., & West, R., 2011). Each guide covers the COM-B diagnosis, primary intervention strategy, tactical recommendations with evidence anchors, evidence-based contraindications, transition pathway, and team-level application notes. A quick-reference matrix summarizing all six personas is provided on the final landscape page.

How to use this guide

Step 1: Complete the scoring and persona classification for each developer using Deliverable 3. Note the persona name and confidence level.

Step 2: Navigate to the corresponding persona section below. Read the COM-B diagnosis before the tactics - the diagnosis explains why the recommended tactics are appropriate for this profile, and why the contraindications are counterproductive.

Step 3: Check whether any of the five Insight Triggers from Deliverable 5 fire for this developer. If T1, T2, T4, or T5 fires, modify the standard recommendations as specified in that trigger's action guidance before deploying.

Step 4: Apply the team-level application notes when the same persona appears in multiple team members - the aggregate dynamics differ from the individual dynamics in ways that affect both the urgency and the design of the intervention.

Step 5: Record planned interventions in the Team Aggregation Grid (Deliverable 4) and set a review date. Re-assess at 3 months for high-urgency profiles (Unaware, Resistant with T4 firing, Enthusiast with T1 firing) and 6 months for others.

PERSONA Skeptic	CAP Moderate Adequate but uneven	OPP Moderate Present but under-used	MOT Low ROI doubt, not absence
COM-B DIAGNOSIS Primary lever: Motivation (reflective) Blocking factor: Perceived low benefit-to-effort ratio Key DASP drivers: D12 (risk perception), D13 (security mindset), D15 (benefits knowledge), D17 (past negative experience)	Behavioral pattern and intervention rationale The Skeptic is capable and operates in an environment that provides at least moderate support, but has not been persuaded that the effort security requires is proportionate to the risk it poses or the value it delivers. This is a reflective motivational deficit, a cognitive appraisal problem, not an emotional or habitual one. The developer consciously evaluates the cost/benefit ratio of security work and finds it unconvincing. DASP D12 captures the core: limited risk perception leads to limited investment. The intervention implication is precise: persuasion must be evidence-based and quantitative, directed at the specific cost-benefit calculus the Skeptic is using, not at attitudes or culture in general. Generic 'security awareness' training that does not address the ROI question will bounce off this profile without effect.		
PRIMARY INTERVENTION STRATEGY Evidence-based ROI persuasion: show the Skeptic concrete, domain-relevant data that reframes the cost-benefit calculus.			
RECOMMENDATIONS 1. Present domain-specific breach data. Show the Skeptic breach and vulnerability statistics from their own industry sector, not generic global figures. The closer the data is to its actual context, the harder it is to discount. SECUR-E notes that Skeptics often believe 'their applications have never been attacked'; real incident data from similar organizations directly challenges this bounded rationality. [DASP D12, D13; Kahneman & Tversky (1979) prospect theory] 2. Quantify the developer-time cost of late vs. early remediation. Provide the Skeptic with organization-specific data showing that security defects found post-release cost significantly more to fix than those caught during development. The argument is that security investment during development is not an additional cost; it is cost avoidance that the Skeptic's current workflow is incurring invisibly. [DASP D15 (knowledge of security benefits); D2 (prioritization argument)] 3. Involve the Skeptic in a security decision with visible impact. Assign the Skeptic a bounded security task, a threat model review, a dependency audit, and a SAST findings triage, so they can observe the concrete effect of their work. Direct experience of security value is more persuasive than secondhand data and bypasses the intellectual resistance that abstract training encounters. DASP D8: automatic motivation develops through direct behavioral engagement. [DASP D8 (motivation through direct behavior); D32 (self-efficacy building)] 4. Address specific past negative experiences explicitly. Skeptics frequently have a history of security processes that were genuinely wasteful, audits that found nothing, tools with high false-positive rates, and compliance theatre that cost time and delivered no security value. DASP D17 identifies past negative experience as a persistent motivational inhibitor. Ask the Skeptic to describe the worst security experience they have had, and then address that specific experience rather than defending security in the abstract. Acknowledge that bad security processes exist and that the goal is better ones. [DASP D17 (past negative experience as barrier); D23 (tool usability)] 5. Connect to a security champion who shares the Skeptic's technical credibility level. Skeptics are more persuaded by peer technical evidence than by security specialist authority. A security champion who is also a respected developer, someone whose code quality the Skeptic admires, can provide evidence-based persuasion with the social credibility that a compliance officer or CISO cannot. DASP D3: security-specific roles are most effective when embedded in the development community rather than serving as external auditors. [DASP D3 (security champion role); D6 (social perception of security as normative)]			

WHAT NOT TO DO - and why *(Evidence-based contraindications)*

1. **Do not: deploy generic security awareness training without customization.** The Skeptic's problem is specifically a cost-benefit appraisal, not a knowledge gap. Generic training that does not address ROI arguments will either bore them (since they already know the content) or reinforce their view that security investment is poorly targeted. DASP D15 distinguishes between awareness and genuine belief in security value; only the latter changes behavior. *[DASP D15, D17]*
2. **Do not: increase compliance enforcement without improving the quality of the security requirements being enforced.** Enforcement pressure on a Skeptic who believes the requirements are disproportionate will produce compliance theatre, surface-level adherence without behavioral change, and will deepen resentment. The Skeptic's position is not 'I won't comply' but 'I don't see why this matters.' Coercion does not answer that question. *[DASP D21 (security as bureaucracy); Brehm (1966) reactance risk]*
3. **Do not: dismiss or avoid the Skeptic's ROI objections in team settings.** A Skeptic who raises a challenge to the value of a security practice and receives a dismissive response ('that's just the policy') will feel their position has been confirmed and that the security advocates cannot defend their own requirements on the merits. Engage the objection directly, with data. Skeptics are usually 'open to persuasion based on evidence'; this is the opening. *[DASP D13 (security mindset development)]*

TRANSITION PATHWAY

Skeptic → Embedded

Realistic timeframe: 6–18 months with sustained evidence-based engagement

What the transition requires

A shift from reflective skepticism to genuine belief in the value of security (DASP D15), followed by behavioral habituation as security tasks become integrated into the normal workflow (DASP D8). The intermediate state, once persuaded but not yet habituated, resembles a high-motivation Compliant profile. The full Embedded transition requires both the belief and the organizational support structure (OPP improvement) to sustain new habits.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

Skeptics are useful diagnostic signals. A team with multiple Skeptics is almost certainly receiving security requirements that lack clear justification or that have been implemented poorly in the past. Before deploying individual interventions, investigate whether the Skeptic's ROI doubts have a legitimate basis in the organization's actual security practices. If security audits have historically been poorly targeted or security tools have been noisy, fix those problems first.

Avoid isolating the Skeptic from the team's security discussions. A Skeptic who is excluded from security conversations, because their objections are treated as obstruction, loses the social exposure to security norms that is one of the few automatic pathways to motivational change (DASP D6). Keep them in the room. The goal is gradual norm exposure, not compliance pressure.

PERSONA Enthusiast	CAP High Strong technical skills	OPP Low Under-resourced env.	MOT High Intrinsic, proactive
COM-B DIAGNOSIS Primary lever: Opportunity (social and technical) Blocking factor: Organizational support gap, motivation is present, but the environment does not match it Key DASP drivers: D1 (security culture), D2 (dedicated time), D3 (security champion role), D9 (tool awareness), D26 (self-directed learning)	Behavioral pattern and intervention rationale The Enthusiast has already solved the motivation and capability problems. The deficit is entirely on the opportunity dimension: the organization does not provide dedicated time, accessible tools, security champions, or a team culture that normalizes security discussion. The Enthusiast compensates through personal initiative, self-directed learning, unofficial tool adoption, and informal peer education, but this compensation is fragile. SECUR-E is explicit: 'If the organizational context remains unsupportive, Enthusiast behavior is unlikely to persist.' The intervention implication is equally explicit: do not attempt to increase motivation or build capability in an Enthusiast. Instead, invest entirely in closing the OPP gap. Every OPP intervention delivered to an Enthusiast has a multiplier effect because the motivation and capability to use the new opportunity already exist.		
PRIMARY INTERVENTION STRATEGY Close the organizational opportunity gap before motivational exhaustion sets in.			
RECOMMENDATIONS 1. Formalize a security champion role. The Enthusiast is already performing the informal functions of a security champion, peer consultation, tool advocacy, and incident awareness. Formalizing this role does three things simultaneously: it validates their existing work (motivational sustainer), it creates a legitimate mandate for security activity that removes the need for constant self-justification, and it provides a structural anchor for the OPP dimension that does not depend on individual goodwill. DASP D3: cited by 14/28 practitioners as a critical organizational opportunity lever. [DASP D3 (security champion role); D1 (organizational culture)] 2. Allocate dedicated, protected security time. The most common Enthusiast failure mode is time; security work competes with delivery pressure, and security loses because there is no explicit time budget. Allocate a formal percentage of sprint capacity or working time to security activities. Even a small protected allocation (10-15%) sends the organizational signal that security is a first-class activity, not an overhead to be squeezed. DASP D2: cited by 17/28 practitioners as the single most important driver of opportunity. [DASP D2 (prioritization); D1 (culture signal)] 3. Fund and provide the tools the Enthusiast has already identified. Enthusiasts typically know exactly which tools they need; they have already researched and trialed them informally. DASP D9 (tool awareness) and D25 (workflow integration) together point to the same action: ask the Enthusiast what tools they would use if they had budget and permission, and provide those tools with formal integration support. This is the highest-ROI tool investment because the selection problem is already solved. [DASP D9 (tool awareness); D25 (workflow integration); D23 (tool usability)] 4. Connect the Enthusiast to an external security community. DASP participants (Enthusiast profile) described how connection to external peers, conference communities, online security forums, and CTF networks was a primary sustainer of motivation when internal culture was weak. If the team's security culture cannot yet sustain the Enthusiast, external community belonging can fill that gap while internal culture develops. DASP D26: self-directed learning through community engagement. [DASP D26 (self-directed learning); D29 (knowledge sharing)] 5. Monitor for and mitigate burnout risk explicitly. Set a formal check-in cadence (quarterly) at which the Enthusiast's motivation and workload balance are assessed. Ask directly: 'Are you being asked to carry more security responsibility than is sustainable?' If the Enthusiast is the sole informal security resource for a team, they are absorbing a systemic organizational risk, and they will absorb it silently until they cannot. SECUR-E identifies this as the Enthusiast's primary fragility. [DASP D2 (time pressure as a barrier)]			

WHAT NOT TO DO - and why *(Evidence-based contraindications)*

1. **Do not: increase the Enthusiast's security responsibilities without increasing their resources.** This is the most common mistake with Enthusiast profiles. Because they are responsive and capable, they are often assigned more security work as implicit recognition of their abilities. Without commensurate resource allocation, this accelerates burnout. Adding responsibility without adding time, tools, or team support is not recognition; it is extraction. *[DASP D2 (time allocation)]*
2. **Do not: treat the Enthusiast as a substitute for organizational security investment.** An organization with one Enthusiast is not a security-capable organization; it is an organization that has socialized a systemic risk onto one individual. If the Enthusiast leaves, changes roles, or burns out, the security posture collapses. The Enthusiast's presence should trigger investment in organizational OPP, not reduce it. *[DASP D1 (culture), D3 (champion role as structural, not individual)]*
3. **Do not: provide generic security motivation training.** The Enthusiast does not have a motivation deficit. Assigning them security awareness training, compliance modules, or attitude surveys wastes their time and signals that the organization does not understand what they need. Worse, it uses up the same protected security time budget that should be spent on meaningful technical work. *[DASP D15 (motivation already present)]*

TRANSITION PATHWAY

Enthusiast → Embedded

Realistic timeframe: 3–9 months with targeted OPP investment

What the transition requires

The Enthusiast is one or two OPP interventions away from Embedded. The transition is gated almost entirely by organizational action, not by anything the developer needs to do differently. Formal champion role assignment + dedicated time allocation is the minimum sufficient condition. Once OPP reaches High, the Enthusiast's existing High CAP and High MOT complete the Embedded profile automatically.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

The Enthusiast is the team's highest-return investment target. A small, targeted OPP investment in an Enthusiast produces a confirmed Embedded developer, the most valuable security resource in the team tier. No other persona transition has a better input-output ratio. If the team has an Enthusiast, they should be the first persona targeted in any intervention cycle.

The Enthusiast is a latent security champion for other personas. Once OPP is closed, an Embedded former-Enthusiast has the technical credibility (High CAP) and genuine belief (High MOT) to be the most effective peer influence on Skeptics and Compliant developers. DASP D3 and D6 both point to peer modeling as the social opportunity mechanism, and the Enthusiast, once supported, is uniquely placed to provide it.

PERSONA Compliant	CAP Moderate Can execute; follows well	OPP High Org support is the primary driver	MOT Low Extrinsic; compliance-framed
COM-B DIAGNOSIS Primary lever: Motivation (reflective → automatic) Blocking factor: Absence of intrinsic motivation; behavior is governed by external enforcement, not personal belief Key DASP drivers: D8 (automatic motivation), D15 (belief in security value), D16 (customer protection mindset), D22 (positive reinforcement)	Behavioral pattern and intervention rationale The Compliant developer does security work because the process requires it, not because they believe in it. DASP participants capture the archetypal response: 'that's what the process requires.' High organizational OPP is doing the motivational work, and this creates a structural fragility: any reduction in enforcement (policy relaxation, team restructuring, reduced audit frequency) will produce a proportional reduction in security behavior. The intervention goal is to shift from this extrinsic, compliance-driven behavioral pattern toward genuine internalized motivation, while being careful not to remove organizational enforcement before the motivational shift is complete. The order of operations matters: build MOT while maintaining OPP, then gradually shift the behavioral driver from compliance to belief.		
PRIMARY INTERVENTION STRATEGY Motivational internalization: build intrinsic belief in security value while maintaining organizational enforcement structures as a safety net during the transition.			
RECOMMENDATIONS 1. Create direct exposure to the human consequences of security failures. DASP D16 identifies 'customer protection mindset' as one of the most effective motivational drivers, the belief that secure code protects real people. For a Compliant developer, this reframing is powerful because it connects security work to values they already hold (professional pride, user welfare) rather than to a compliance obligation. Use real-world case studies: healthcare data breaches, identity theft cases, infrastructure attacks. Make the human cost visceral and concrete. [DASP D16 (customer protection mindset); D15 (security value beliefs)] 2. Acknowledge and reward security initiatives, not just security compliance. Compliant developers receive positive feedback for following security procedures, which reinforces compliance behavior. To shift toward intrinsic motivation, change the reinforcement structure: explicitly recognize and reward instances where the developer identifies a security risk proactively, suggests a security improvement voluntarily, or takes a security action that was not required. DASP D22: positive reinforcement shapes the direction of security behavior. [DASP D22 (positive reinforcement); D8 (transition to automatic motivation)] 3. Assign increasing security autonomy progressively. The Compliant developer is accustomed to receiving clear security directives. To build intrinsic motivation, gradually increase their autonomy over security decisions: start with small choices (which linting rules to enforce, which SAST findings to prioritize) and escalate over time. Each autonomous security decision that goes well reinforces the developer's sense of personal agency over security outcomes, which is a precursor to intrinsic motivation (Self-Determination Theory - SDT): internalization through autonomy support. [DASP D8 (motivation autonomy); D20 (security autonomy); SDT internalization] 4. Connect the Compliant developer to an Embedded or Enthusiast peer. The most effective motivational shift for a Compliant developer is social: observing a respected peer who treats security as personally meaningful rather than merely procedurally required. DASP D6 (social perception of security as normative behavior) operates powerfully here because the Compliant developer is already highly responsive to social cues; that is what makes them Compliant. Redirect the same social responsiveness from compliance norms toward intrinsic norms by changing the peer reference group. [DASP D6 (social opportunity); D3 (champion as peer model)] 5. Do not remove organizational enforcement prematurely. When a Compliant developer begins showing signs of intrinsic motivation (higher MOT scores, voluntary security initiatives), the instinct may be to reduce enforcement as a trust signal. Resist this. Continue organizational enforcement while MOT grows, reducing it only once the developer has sustained two or more assessment cycles of High MOT. Premature removal of extrinsic			

enforcement before intrinsic motivation is consolidated risks a behavioral collapse. [DASP D8 (order of operations); Tyler & Blader (2005) internalization theory]

WHAT NOT TO DO - and why (Evidence-based contraindications)

1. **Do not: reduce organizational security enforcement to test motivational independence.** A Compliant developer whose behavior is driven by extrinsic enforcement will not 'step up' to fill an enforcement gap; they will simply do less security work. This is not weakness or bad faith; it is the behavioral logic of the extrinsic motivation pattern. Enforcement reduction before intrinsic motivation is consolidated produces a direct security regression. [DASP D8 (extrinsic-to-intrinsic order); Tyler & Blader (2005)]
2. **Do not: interpret stable compliance as successful intervention.** A Compliant developer who maintains consistent security behavior across two assessment cycles without any MOT improvement is not progressing; they remain in the same fragile extrinsic state. Track MOT scores over time, not just behavioral outputs. The intervention has not succeeded until MOT has moved into the Moderate range. [DASP D8, D15]
3. **Do not: assign the Compliant developer to security champion or leadership roles before MOT has shifted.** A security champion who is themselves Compliant will model compliance behavior, following security requirements because they are mandated, rather than the intrinsically motivated behavior that peer modeling is supposed to transmit. Champions must have genuine High MOT to produce the motivational social contagion that DASP D3 and D6 describe. [DASP D3 (champion role requires genuine motivation); D6 (social modeling mechanism)]

TRANSITION PATHWAY

Compliant → Embedded

Realistic timeframe: 9-18 months; the Compliant-to-Embedded transition is the slowest in the system because it requires genuine motivational internalization, not just skill or resource acquisition

What the transition requires

MOT must reach High through genuine internalization (DASP D8, D15) while OPP remains High. The intermediate milestone occurs when the developer begins to voluntarily initiate security actions, a behavioral signal that intrinsic motivation has begun to take hold. DASP participants documented this transition: 'I started checking for security issues before I was asked to.' Trigger T5 (Transition Opportunity, D5) fires at this milestone; it is the signal to accelerate rather than maintain the current intervention intensity.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

Compliant developers are highly sensitive to changes in team security norms. When an organization's security culture strengthens, new policies, more visible enforcement, and the introduction of a security champion lead to compliant developers being among the fastest responders. Conversely, when security norms weaken, they are among the first to reduce security effort. Use them as a leading indicator: if Compliant developers' security behavior declines unexpectedly, investigate whether organizational enforcement has weakened before assuming individual motivational regression.

Multiple Compliant developers signal organizational security maturity, not individual success. A team where most developers are Compliant has achieved something real, consistent security behavior, but through an organizationally expensive and fragile mechanism. The investment goal should be to convert at least some Compliant developers to Embedded over time, creating a self-sustaining team security culture that does not depend entirely on enforcement for its maintenance.

PERSONA Unaware	CAP Very Low Foundational gaps	OPP Very Low Cannot engage resources	MOT Very Low Invisible, not resistant
COM-B DIAGNOSIS Primary lever: Capability (foundational, must be addressed before any other lever) Blocking factor: Metacognitive gap: the developer does not know what they do not know, which means they cannot identify their own learning needs or respond to opportunities or motivational interventions that require baseline knowledge to engage with Key DASP drivers: D28 (security training effectiveness), D31 (non-technical communication), D32 (self-efficacy), D33 (awareness of necessary skills)	Behavioral pattern and intervention rationale The Unaware developer presents the most fundamental challenge in the system and, simultaneously, the clearest path for intervention. The problem is not resistance, cynicism, or environmental failure; it is invisibility. Security is not on the Unaware developer's cognitive map. They cannot recognize security problems, evaluate security tools, respond to security champions, or act on security policies because they do not have the foundational schema that any of these resources assumes. DASP documents the Dunning-Kruger dynamic: Unaware developers often have moderate or even high confidence in their ability to handle security, which masks the gap from both themselves and their colleagues. The intervention order is non-negotiable: capability must come first. Providing opportunity resources (tools, champions) or motivational interventions (ROI arguments, customer protection framing) to an Unaware developer is a wasted investment because they cannot engage productively with any of these until foundational knowledge is in place.		
PRIMARY INTERVENTION STRATEGY Foundational capability building first, using accessible, scaffolded, immediately applicable formats, before any motivational or opportunity intervention.			
RECOMMENDATIONS 1. Begin with the concrete and immediately applicable, not the theoretical. DASP D28 identifies specific training design features that produce behavioral change in security-aware developers: concrete examples, hands-on exercises, immediate workflow application. For Unaware developers, these design features are even more critical; abstract threat modeling frameworks or compliance terminology will not land without a foundation. Start with one class of vulnerability (e.g., injection flaws) in the developer's own language and stack, demonstrated in code they recognize. Expand scope progressively once the first domain is consolidated. [DASP D28 (training effectiveness); D33 (targeted skill development)] 2. Build metacognitive awareness explicitly alongside technical content. DASP D33 (awareness of necessary security skills) is the metacognitive complement to D32 (technical self-efficacy). An Unaware developer who completes foundational training but does not develop a clear picture of what they still need to learn will plateau. Build explicit skill maps into the training: 'You now understand injection flaws; the adjacent skills you should develop next are authentication weaknesses and dependency management.' This gives the developer a roadmap that makes continued learning tractable rather than infinite. [DASP D33 (skill gap awareness); D32 (self-efficacy)] 3. Pair the Unaware developer with an Embedded or Enthusiast mentor. Social learning (DASP D6, D29) is particularly effective for Unaware developers because it provides ongoing calibration: the mentor can see gaps the Unaware developer cannot see in themselves, and can frame security problems in terms the developer already understands. The mentor relationship also provides the motivational signal that security is worth learning, not through abstract arguments but through demonstrated technical peer respect. [DASP D6 (social opportunity); D29 (knowledge sharing); D3 (champion as mentor)] 4. Measure and visibly celebrate early capability milestones. Unaware developers often find early security learning disorienting; they discover how much they did not know, which can be demotivating. Counteract this by defining and celebrating small, concrete milestones: 'You correctly identified three injection risk points in the code review.' DASP D22 (positive reinforcement) and D32 (self-efficacy building) both point to the importance of early wins in establishing the motivational foundation for continued engagement. [DASP D22 (positive reinforcement); D32 (self-efficacy development)]			

5. **Protect the Unaware developer from security tool overload during the foundational phase.** Security tools assume knowledge that the Unaware developer does not yet have. Introducing SAST tools, dependency scanners, or threat modeling software before developers have foundational knowledge leads to alert fatigue, tool rejection, and reinforcement of the belief that security is incomprehensible. Introduce tools only after the developer can evaluate the output themselves, typically after 2–3 months of foundational training. *[DASP D23 (tool usability); D9 (tool awareness progressive)]*

WHAT NOT TO DO - and why *(Evidence-based contraindications)*

1. **Do not: deploy motivational interventions before capability is established.** Arguments about security ROI, customer protection framing, or security culture programs require the developer to have a baseline understanding of what security problems look like in order to evaluate why they matter. An Unaware developer presented with a data breach case study may engage empathetically but cannot connect it to their own code because they do not yet have the conceptual vocabulary to do so. Motivational investment before capability is in place is ineffective, not harmful, but it wastes a limited intervention budget. *[DASP D12, D15 (motivation requires baseline capability)]*
2. **Do not: assume the Unaware developer's confidence signals competence.** DASP explicitly names the Dunning-Kruger dynamic for Unaware developers: 'extensive development experience can produce false confidence in security ability.' A developer who says 'I know about security, I just don't worry about it' may be expressing the Skeptic's conscious ROI doubt, or may be expressing the Unaware developer's inability to see what they cannot see. Use the instrument (specifically CAP-6 and CAP-8 item responses, plus Reflection 2) to distinguish between these two patterns before deploying interventions. *[DASP D32 (overconfidence as metacognitive gap); D33]*
3. **Do not: treat slow progress as a motivation or attitude problem.** Foundational capability building is slow by its nature; it requires schema construction, not just information transfer. An Unaware developer who is progressing at the expected pace of foundational learning should not be redirected to motivational interventions or escalated to management for a performance concern. Reframing slow capability growth as a motivational failure adds social pressure to a learning challenge, thereby inhibiting rather than accelerating progress. *[DASP D28 (training design patience); D32 (self-efficacy fragility in early stages)]*

TRANSITION PATHWAY

Unaware → Skeptic

Realistic timeframe: 6–12 months to reach Skeptic/Compliant entry threshold; 18–36 months to Embedded

What the transition requires

The immediate goal is not Embedded but the next viable profile: either Skeptic (if the foundational capability reaches Moderate and the developer has their own cost-benefit questions) or Compliant (if organizational enforcement and OPP support are strong and the developer can reliably follow security procedures). The Skeptic transition is preferable because it preserves the motivational signal that the developer is engaging with security on their own terms. The Embedded transition is a long-range goal requiring sustained investment across all three dimensions.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

An Unaware developer in a team is a systemic vulnerability, not an individual one. Any code the Unaware developer contributes to shared repositories, pipelines, or APIs affects the security posture of the entire codebase. The team's security investment is partially undermined as long as one member cannot recognize or respond to security risks in their own work. The Unaware developer's intervention should be prioritized at the team level, not only as an individual development goal.

Do not isolate the Unaware developer from team security discussions while they are building capability. The instinct to shield an Unaware developer from security discussions they cannot yet engage with productively is well-intentioned but counterproductive. Passive exposure to security conversations, hearing colleagues discuss vulnerability patterns, security tools, or incident responses, provides contextual learning that supplements formal training. Keep the Unaware developer in security-relevant meetings even before they can contribute, and pair them with a mentor who can decode the discussion afterward.

PERSONA Resistant	CAP Moderate Capable, but disengaged	OPP Moderate Support exists, but is not valued	MOT Very Low Active opposition; reactance
COM-B DIAGNOSIS Primary lever: Motivation (automatic/identity), through autonomy, not compliance Blocking factor: Psychological reactance: security requirements are experienced as autonomy threats, producing active opposition rather than mere indifference Key DASP drivers: D20 (security autonomy), D21 (flexibility in security processes), D24 (reducing cognitive effort), D17 (addressing past negative experience)	Behavioral pattern and intervention rationale The Resistant developer is the most misunderstood profile in the system, and the most frequently mis-managed. They are not ignorant (CAP is Moderate), they are not unsupported (OPP is Moderate), and they are not merely indifferent. They are actively opposed, and the opposition has a specific psychological structure: psychological reactance (Brehm, 1966). Security requirements, as experienced by the Resistant developer, are constraints on professional autonomy, impositions that interrupt their workflow, second-guess their judgment, and treat them as incapable of making security decisions themselves. The more the organization responds to this opposition with increased enforcement and compliance pressure, the stronger the reactance becomes. DASP is explicit: 'security guidelines are unhelpful and unnecessary, and they actively resist or avoid security practices.' The intervention logic is the direct inverse of what most compliance programs deploy: the only path to motivational change in a Resistant developer is through increasing their sense of autonomy and control over security decisions, not reducing it.		
PRIMARY INTERVENTION STRATEGY Autonomy-preserving security redesign: reframe security as a craft decision the developer controls, not a compliance obligation imposed from outside.			
RECOMMENDATIONS 1. Remove the Resistant developer from mandatory security training tracks. Mandatory training is the most direct trigger for reactance in a Resistant profile. Every mandatory module communicates 'we do not trust you to decide how to approach security,' which deepens rather than resolves the motivational opposition. Replace mandatory training with optional, developer-controlled security learning opportunities: recommended reading lists, conference access, CTF participation. The act of removing the mandate is itself motivationally meaningful. [DASP D20 (autonomy in security practice); D21 (flexibility); Brehm (1966) reactance theory] 2. Involve the Resistant developer in the design of security processes, not just their execution. Reactance is strongest when constraints are experienced as externally imposed. Involve the Resistant developer in deciding how security requirements are implemented, the specific format of code reviews, the configuration of SAST tool thresholds, and the criteria for security sign-off. When the developer has co-authored a security process, it is experienced as their own decision rather than an external imposition. DASP D21: flexibility in how security is implemented, not whether it is implemented. [DASP D21 (security process flexibility); D20 (developer autonomy)] 3. Address specific past experiences of bad security processes directly. DASP D17 identifies past negative experiences with security processes as a primary motivational inhibitor. Resistant developers frequently have concrete grievances: a security audit that produced no actionable findings, a tool that flagged false positives at high rates, a compliance requirement that had no security rationale. Ask for and take these grievances seriously. Acknowledge that bad security processes exist. Show that the current approach is different, with specific evidence. This is not capitulation; it is credibility-building. [DASP D17 (past negative experience); D23 (tool quality)] 4. Reduce the cognitive friction of required security activities. DASP D24 identifies cognitive effort reduction as a key motivational lever for developers who experience security as burdensome. For the Resistant developer, high-friction security activities (verbose documentation, disruptive workflow interruptions, slow tools) provide concrete evidence that security is poorly designed, confirming their worldview. Reduce friction aggressively: automate what can be automated, integrate tools into the existing workflow rather than adding parallel workflows, and reduce the procedural overhead of security compliance. [DASP D24 (cognitive effort reduction); D25 (workflow integration); D23 (tool usability)]			

5. **Distinguish reactance from legitimate critique, and act on the latter.** Not every Resistant developer objection is pure reactance. Some security processes are genuinely poorly designed, wasteful, or redundant, and the Resistant developer, who pays close attention to security costs, may be identifying real problems that Compliant or Unaware colleagues are silently absorbing. Treat each objection as potentially containing a legitimate critique. When the critique is valid, act on it visibly. When it is reactance rather than critique, address the autonomy dimension rather than the objection's content. [DASP D21, D23]

WHAT NOT TO DO - and why *(Evidence-based contraindications)*

1. **Do not: escalate compliance pressure or enforcement in response to resistance.** Compliance pressure is the direct antecedent of reactance escalation. A Resistant developer who is responding to enforcement with opposition will respond to increased enforcement with increased opposition, potentially triggering the T4 (Resistant Escalation Risk) insight trigger. The more an organization doubles down on compliance as the response to resistance, the more entrenched the motivational opposition becomes. This is the single most common mis-management pattern for this persona. [Brehm (1966) reactance theory; DASP D20, D21]
2. **Do not: engage the Resistant developer's objections purely at the content level without addressing the autonomy dimension.** A Resistant developer who objects that 'this SAST tool produces too many false positives' may have a valid point about the tool, but the deeper issue is that the tool was imposed without their input. Replacing the tool with a better one without involving the developer in the selection will likely produce a new objection about the replacement. The content of objections changes; the autonomy deficit does not, until it is directly addressed. [DASP D20 (autonomy need); Brehm (1966)]
3. **Do not: exclude the Resistant developer from security decision-making because of their opposition.** The instinct to remove the Resistant developer from security conversations, because their participation produces friction, removes the one intervention that is most likely to shift their motivation: meaningful participation in shaping security decisions. Exclusion communicates 'your judgment is not trusted,' which is precisely the message that generated the reactance in the first place. [DASP D20 (participation as autonomy)]

TRANSITION PATHWAY

Resistant → Skeptic

Realistic timeframe: 6–18 months; the Resistant-to-Skeptic transition is achievable, but Embedded is typically a multi-year trajectory from this starting point

What the transition requires

The immediate goal is not Embedded but Skeptic, a state where the opposition has been replaced by conscious cost-benefit evaluation. This requires breaking the reactance cycle (through autonomy restoration) and replacing it with genuine intellectual engagement with the security ROI question. Once the developer is asking 'is this security effort worth it?' rather than 'why are you imposing this on me?', the Skeptic-targeted interventions (evidence-based persuasion) become applicable.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

A single Resistant developer can destabilize team security norms through social influence. DASP D6 (social perception of security as normative) operates in both directions: positive champions increase security norms, but vocal opponents can erode them. A Resistant developer who expresses security objections openly and persistently in team settings provides ongoing social cover for Skeptics and Compliant developers to deprioritize security. The team-level urgency of the Resistant intervention is partly about protecting the motivational investments made in other developers.

Do not confuse the Resistant developer with the Skeptic in team interventions. A team intervention that uses evidence-based ROI arguments to shift Skeptics, showing breach data and cost-of-late-remediation figures, will typically make a Resistant developer more resistant, not less. The Resistant developer interprets the presentation of evidence as another attempt to compel their compliance. Separate the intervention streams: deliver the evidence-based session to Skeptics with the Resistant developer's participation made optional, not mandatory.

PERSONA Embedded	CAP High Expert and meta-aware	OPP High Fully supported environment	MOT High Habitual, identity-level
COM-B DIAGNOSIS Primary lever: No primary deficit, sustain and amplify Blocking factor: Risk of invisible stagnation: Embedded developers can experience stagnation if they lack opportunities for growth, peer challenges, or formal acknowledgment of their leadership in security. Key DASP drivers: <i>D3 (champion role formalization), D26 (continued self-directed learning), D29 (knowledge sharing), D30 (security community engagement), D32 (continued self-efficacy development)</i>	Behavioral pattern and intervention rationale The Embedded developer has internalized security as a core professional value and practices it habitually. DASP provides the defining self-description: 'making sure my code is secure is just as important as making sure it works' and 'it's just part of how I code.' All three COM-B dimensions are High. The organizational environment supports their security work (High OPP); they have the technical and metacognitive capability to engage with complex security problems (High CAP), and their motivation is intrinsic, automatic, and identity-level (High MOT). The intervention goal for an Embedded developer is not remediation; it is strategic deployment. The organization's primary task is to prevent this profile from becoming invisible, stagnant, or poorly leveraged. An Embedded developer who is not given formal recognition, expanding scope, or meaningful peer influence channels will, over time, reduce their security investment to match what the organization actually rewards, which, in most organizations, is delivery speed rather than security depth.		
PRIMARY INTERVENTION STRATEGY Sustain, recognize, and strategically deploy: formalize the Embedded developer's security leadership role and invest in their continued development to prevent stagnation and maximize their influence on other personas.			
EXEMPLAR Sub-Flag <i>(D3, Rule 2a: applies when CAP, OPP, and MOT are all Very High, ≥37 raw)</i> Treat this as a prioritization signal within Embedded, not a separate persona or a different intervention. Where a team has more than one Embedded developer, use the Exemplar flag to decide who receives the formal champion mandate, conference or training budget, and primary mentoring assignment first, rather than treating every Embedded developer as equally ready for the same investment. The absence of the flag does not mean a developer is unready to be a champion; it means the case for prioritizing them ahead of other Embedded developers on the team is not yet quantitatively distinguished. All recommendations below apply to every Embedded developer regardless of Exemplar status.			
RECOMMENDATIONS 1. Formalize as a security champion with an explicit mandate and dedicated time. An Embedded developer who is informally performing security leadership functions deserves a formal title, a protected time budget, and organizational authority to act on security findings. DASP D3: Security champion roles are most effective when formally recognized rather than as informal add-ons to existing roles. Formalization also signals to the rest of the team that security leadership is valued at the organizational level, thereby strengthening the social opportunity dimension for all other developers (DASP D6). <i>[DASP D3 (champion role formalization); D6 (social norm transmission)]</i> 2. Invest in continued technical deepening. DASP D26 (self-directed learning) and D30 (security community engagement) identify continued investment in professional development as both a motivational sustainer and a capability builder for high-engagement developers. Fund the Embedded developer's participation in security conferences, advanced training, CTF competitions, or open-source security projects. Beyond the direct capability value, this investment signals that the organization takes its security expertise seriously, which is itself a motivational sustainer. <i>[DASP D26 (self-directed learning); D30 (community engagement); D32 (continued self-efficacy growth)]</i> 3. Assign the Embedded developer as the primary mentor for Unaware and Enthusiast colleagues. The Embedded developer is uniquely positioned to accelerate two other persona transitions: they can provide the technical scaffolding that Unaware developers need (DASP			

D28, D29) and the organizational social proof that Enthusiasts need to sustain motivation in the face of environmental resistance. DASP D29 (knowledge sharing) is most effective when it flows from a developer who both knows the content and embodies the motivational model. [DASP D29 (knowledge sharing); D3 (mentor as champion)]

4. **Give the Embedded developer influence over security processes and tooling decisions.** An Embedded developer who has no voice in how security is implemented will, over time, experience a widening gap between their own security standards and the organizational processes they are required to follow. This gap is demoralizing in proportion to the developer's security expertise; the more they know, the more visible the inadequacy of poor processes becomes. Involve them in security architecture decisions, tool selection, policy drafting, and threat model design. [DASP D20 (security autonomy); D21 (process influence); D1 (culture shaping from within)]
5. **Monitor for and prevent security isolation.** An Embedded developer on a team with multiple Skeptics, Compliers, and Resistant developers may, over time, become isolated, their security standards are higher than the team culture supports, and they may begin to experience their security work as professionally lonely. DASP identifies this as a real risk. Counter it by connecting the Embedded developer to an external security community (DASP D30) and by ensuring they have at least one peer within the organization at a comparable engagement level. [DASP D30 (external security community)]

WHAT NOT TO DO - and why *(Evidence-based contraindications)*

1. **Do not: assume the Embedded developer requires no intervention because they are performing well.** The Embedded profile is self-sustaining only as long as the organizational conditions that support it are maintained. Organizational changes, new management, team restructuring, increased delivery pressure, cuts to the security champion program, can erode OPP, even for an Embedded developer. Regular check-ins and investment maintenance are still required. 'No news is good news' is a dangerous management heuristic for this profile. [DASP D1 (organizational culture as sustainer)]
2. **Do not: overload the Embedded developer with security responsibilities that should be distributed.** Because the Embedded developer is reliable and high-performing on security tasks, they are often implicitly assigned more security work than is sustainable. This mirrors the Enthusiast burnout risk but with an additional organizational dependency problem: the Embedded developer may have become the de facto security function for the team, meaning their departure or overload failure takes the entire team's security posture down with them. [DASP D2 (time allocation); DASP D3 (champion role as distributed, not individual)]
3. **Do not: assign generic security awareness training that is below the developer's existing level.** An embedded developer who is assigned to introductory security training quickly realizes that the organization does not recognize the gap between their expertise and the training level. This situation is not only a waste of time but also sends a discouraging message that the organization either overlooks or undervalues their security skills. It's essential to align all professional development investments with the developer's actual skill level. [DASP D26, D32]

TRANSITION PATHWAY

Embedded → Embedded

Realistic timeframe: Stable, sustain the current profile, and prevent regression

What the transition requires

The Embedded developer is at the destination state. The relevant question is not transition but succession: developing the next generation of Embedded developers from the Enthusiast and Compliant profiles currently in the team, with the Embedded developer as the primary peer model and mentor. Organizational investment in Embedded developers pays a compound return through their influence on other persona transitions.

TEAM-LEVEL APPLICATION *What changes when this persona is present in a team (not just individually)*

The Embedded developer is the team's most valuable security asset. No other persona generates as much security value per unit of organizational investment. An Embedded developer delivers high-quality secure code, identifies security risks in others' work, builds team security norms through peer modeling, mentors lower-profile developers, and provides organizational credibility for security

investments. The ROI on investment in this developer's continued development and retention is the highest in the entire system.

The Embedded developer's departure represents a disproportionate security risk. If an Embedded developer leaves the team, the team loses not just their individual security output but also the social opportunity function they were providing: peer modeling, norm transmission, and informal mentoring. The team's aggregate security posture will decline across multiple dimensions simultaneously. Retention of Embedded developers should be an explicit organizational priority, with the security function they provide made visible in retention conversations.

Applying This Guide Across the Full System

Delivering a single persona-specific intervention is straightforward. The harder problem is sequencing interventions across a diverse team where multiple personas are present simultaneously, where some interventions benefit one persona while harming another, and where organizational resources constrain what can be deployed in parallel.

Three sequencing principles follow directly from the intervention data in this guide. First, the Unaware intervention cannot be deferred. An Unaware developer's ongoing code contributions are a live security risk to the shared codebase, and capability building is slow. Start this intervention first, in parallel with everything else. Second, do not deploy team-wide motivational interventions (ROI arguments, security culture programs, awareness campaigns) before ensuring the Resistant developer is on an autonomy-preserving track. A team-wide session that uses compliance-framing will deepen Resistant opposition at exactly the moment it is trying to build Skeptic motivation. Third, invest in the Enthusiast first among the non-critical profiles. The Enthusiast-to-Embedded transition is the fastest, the most resource-efficient, and the one that produces the team's next security champion, who then accelerates every other persona's progress.

The 'What NOT to Do' sections are in many ways the most practically valuable part of this guide. Most security programs already know approximately what good security training and culture-building look like. What they do not know, because most frameworks do not provide this level of specificity, is which standard security interventions will backfire for which developer profiles. The contraindications in this guide are anchored to specific psychological mechanisms (Brehm reactance, Dunning-Kruger metacognition, Tyler internalization theory) and to specific DASP evidence. They are not intuitions. Apply them with the same seriousness as the positive recommendations.

A note on the DASP driver code system

Each tactic and contraindication in this guide references DASP driver codes (D1-D33). These codes correspond to the 33 behavioral drivers identified in Larios-Vargas et al. (2023) across seven categories: technical opportunity, social opportunity, organizational factors, reflective motivation, automatic motivation, physical capability, and psychological capability. The full driver descriptions and category mappings are in DASP Table 3 (TSE 49(4), 2023).

SECUR-E Quick-Reference Intervention Matrix - All Six Personas

One-row summary per persona: primary lever, strategy, key tactics, contraindications, transition target, and DASP evidence anchors. Use for rapid practitioner reference and planning. See the full persona cards above for complete guidance.

Persona	Primary Lever	Strategy	Key Tactics (summary)	NOT To Do	Transition	DASP Anchors
Skeptic	Motivation (reflective)	Evidence-based ROI persuasion: show the Skeptic concrete, domain-relevant data that reframes the cost-benefit calculus.	Present domain-specific breach data; Quantify the developer-time cost of late vs. early remediation; Involve the Skeptic in a security decision with visible impact; Address specific past negative experiences explicitly; Connect to a security champion who shares the Skeptic's technical credibility level	Do not: deploy generic security awareness training without customization. Do not: increase compliance enforcement without improving the quality of the security requirements being enforced. Do not: dismiss or avoid the Skeptic's ROI objections in team settings.	Skeptic ↓ Embedded	<i>D12 (risk perception), D13 (security mindset), D15 (benefits knowledge), D17 (past negative experience)</i>
Enthusiast	Opportunity (social and technical)	Close the organizational opportunity gap before motivational exhaustion sets in.	Formalize a security champion role; Allocate dedicated, protected security time; Fund and provision the tools the Enthusiast has already identified; Connect the Enthusiast to an external security community; Monitor for and mitigate burnout risk explicitly	Do not: increase the Enthusiast's security responsibilities without increasing their resources. Do not: treat the Enthusiast as a substitute for organizational security investment. Do not: provide generic security motivation training.	Enthusiast ↓ Embedded	<i>D1 (security culture), D2 (dedicated time), D3 (security champion role), D9 (tool awareness), D26 (self-directed learning)</i>
Compliant	Motivation (reflective → automatic)	Motivational internalization: build intrinsic belief in security value while maintaining organizational enforcement structures as a safety net during the transition.	Create direct exposure to the human consequence of security failures; Acknowledge and reward security initiative, not just security compliance; Assign increasing security autonomy progressively; Connect the Compliant developer to an Embedded or Enthusiast peer; Do not remove organizational enforcement prematurely	Do not: reduce organizational security enforcement to test motivational independence. Do not: interpret stable compliance as successful intervention. Do not: assign the Compliant developer to security champion or leadership roles before MOT has shifted.	Compliant ↓ Embedded	<i>D8 (automatic motivation), D15 (belief in security value), D16 (customer protection mindset), D22 (positive reinforcement)</i>
Unaware	Capability (foundational, must be addressed before any other lever)	Foundational capability building first, using accessible, scaffolded, immediately applicable formats, before any motivational or	Begin with the concrete and immediately applicable, not the theoretical; Build metacognitive awareness explicitly alongside technical content; Pair the Unaware developer with an Embedded or Enthusiast mentor;	Do not: deploy motivational interventions before capability is established. Do not: assume the Unaware developer's confidence signals competence.	Unaware ↓ Skeptic	<i>D28 (security training effectiveness), D31 (non-technical communication), D32 (self-efficacy), D33 (awareness of necessary skills)</i>

Persona	Primary Lever	Strategy	Key Tactics (summary)	NOT To Do	Transition	DASP Anchors
		opportunity intervention.	Measure and visibly celebrate early capability milestones; Protect the Unaware developer from security tool overload during the foundational phase	Do not: treat slow progress as a motivation or attitude problem.		
Resistant	Motivation (automatic/identity) , through autonomy, not compliance	Autonomy-preserving security redesign: reframe security as a craft decision the developer controls, not a compliance obligation imposed from outside.	Remove the Resistant developer from mandatory security training tracks; Involve the Resistant developer in the design of security processes, not just their execution; Address specific past experiences of bad security processes directly; Reduce the cognitive friction of required security activities; Distinguish reactance from legitimate critique and act on legitimate critique	Do not: escalate compliance pressure or enforcement in response to resistance. Do not: engage the Resistant developer's objections purely at the content level without addressing the autonomy dimension. Do not: exclude the Resistant developer from security decision-making because of their opposition.	Resistant ↓ Skeptic	<i>D20 (security autonomy), D21 (flexibility in security processes), D24 (reducing cognitive effort), D17 (addressing past negative experience)</i>
Embedded	No primary deficit, sustain and amplify	Sustain, recognize, and strategically deploy: formalize the Embedded developer's security leadership role and invest in their continued development to prevent stagnation and maximize their influence on other personas.	Formalize as a security champion with explicit mandate and dedicated time; Invest in continued technical deepening; Assign the Embedded developer as the primary mentor for Unaware and Enthusiast colleagues; Give the Embedded developer influence over security process and tooling decisions; Monitor for and prevent security isolation	Do not: assume the Embedded developer requires no intervention because they are performing well. Do not: overload the Embedded developer with security responsibilities that should be distributed. Do not: assign generic security awareness training that is below the developer's existing level.	Embedded ↓ Embedded	<i>D3 (champion role formalization), D26 (continued self-directed learning), D29 (knowledge sharing), D30 (security community engagement), D32 (continued self-efficacy development)</i>

Intervention priority sequence <i>Unaware</i>, start immediately; capability building is slow, and a live code risk exists. <i>Enthusiast</i>, highest ROI persona transition; fastest path to a new security champion. <i>Resistant</i>, highest social risk; one Resistant developer can erode team security norms. <i>Skeptic</i>, evidence-based persuasion; can be run in parallel with Enthusiast/Resistant tracks. <i>Compliant</i>, motivational internalization; longest timeframe, but each transition reduces systemic fragility.	Cross-persona cautions - Team-wide motivational sessions (ROI arguments, culture programs) harm Resistant developers if compliance-framed. Separate Resistant and Skeptic streams. - Mandatory training assigned to Resistant developers will deepen reactance. Make it optional before any other Resistant intervention. - Do not appoint Compliant developers as security champions until MOT has reached Moderate. Compliant champions model compliance, not intrinsic engagement.	Review cadence <i>3-month review</i>: Unaware (T3 systemic trigger); Enthusiast with T1 firing; Resistant with T4 firing; any Compliant with T5 transition opportunity. <i>6-month review</i>: Skeptic; Compliant (standard); Resistant (standard, no T4). <i>Annual review</i>: Embedded (sustain and prevent stagnation). Connect annual review to formal champion role check-in and professional development planning.
---	--	--

All interventions in this guide are grounded in DASP (Larios-Vargas et al., 2023, IEEE TSE 49(4): 33 behavioral drivers from 28 practitioners) and the COM-B Model (Michie et al., 2011). Additional theoretical anchors: Self-Determination Theory (Deci & Ryan), Psychological Reactance Theory (Brehm, 1966), Prospect Theory (Kahneman & Tversky, 1979). Exemplar note: within the Embedded row above, D3's Rule 2a (CAP, OPP, and MOT all Very High, ≥37 raw) flags a sub-priority for teams with more than one Embedded developer; see the Exemplar Sub-Flag row on the full Embedded persona card for detail. It does not change the Strategy, Key Tactics, NOT To Do, or Transition columns for Embedded in this matrix; those apply to every Embedded developer regardless of Exemplar status.